

REPORT 2 – Remediation delle Vulnerabilità

1. Obiettivo della Remediation

A seguito della scansione di sicurezza eseguita tramite **Tenable Nessus Essentials** sulla macchina virtuale **Metasploitable 2**, sono state individuate numerose vulnerabilità di gravità **Critical** e **High**.

In conformità con la traccia dell'esercitazione, sono stati eseguiti interventi di **hardening** e **remediation** finalizzati alla riduzione della superficie di attacco del sistema. Sono state corrette quattro vulnerabilità critiche e, come intervento aggiuntivo, è stata mitigata una quinta vulnerabilità mediante una regola firewall.

Le modifiche apportate sono state successivamente verificate attraverso una nuova scansione di validazione.

2. Dettaglio degli interventi eseguiti

Vulnerabilità 1 – VNC Server "password" Password Detection

Analisi

Il servizio VNC, in ascolto sulla porta **5900**, utilizzava credenziali di default estremamente deboli. Questa configurazione avrebbe consentito ad un eventuale attaccante di ottenere l'accesso remoto all'interfaccia grafica del sistema.

Intervento eseguito

È stato arrestato il processo del server VNC per eliminare completamente l'esposizione del servizio.

Comando utilizzato

```
-sudo killall Xtightvnc
```

Risultato

Il servizio VNC non risulta più raggiungibile dalla rete.

Vulnerabilità 2 – rexecd Service Detection

Analisi

Il servizio **rexecd**, in ascolto sulla porta **514**, permette l'esecuzione remota di comandi tramite un protocollo ormai obsoleto e privo di cifratura.

Intervento eseguito

È stato disattivato il super-demone **openbsd-inetd**, responsabile della gestione del servizio.

Comando utilizzato

```
-sudo /etc/init.d/openbsd-inetd stop
```

Risultato

Il servizio rexecd non risulta più disponibile.

Vulnerabilità 3 – Bind Shell Backdoor Detection

Analisi

La macchina espose una **Bind Shell** sulla porta **1524**, consentendo l'esecuzione remota di comandi.

Intervento eseguito

Poiché la Bind Shell dipende dal servizio **inetd**, la sua disattivazione ha eliminato automaticamente anche questo vettore di attacco.

Comando utilizzato

```
-sudo /etc/init.d/openbsd-inetd stop
```

Risultato

La porta non risulta più esposta durante la successiva scansione.

Vulnerabilità 4 – NFS Exported Share Information Disclosure

Analisi

Il servizio **NFS**, in ascolto sulla porta **2049**, permetteva la condivisione di directory con permessi troppo permissivi, consentendo l'accesso remoto ai file esportati.

Intervento eseguito

Il server NFS è stato arrestato.

Comando utilizzato

```
-sudo /etc/init.d/nfs-kernel-server stop
```

Risultato

Le condivisioni NFS non risultano più accessibili.

Vulnerabilità 5 (Bonus) – vsftpd 2.3.4 Backdoor

Analisi

Il server FTP utilizzava la versione **vsftpd 2.3.4**, nota per la presenza di una backdoor.

Intervento eseguito

Invece di rimuovere il servizio, è stata applicata una regola firewall tramite **iptables** per bloccare tutte le connessioni TCP dirette alla porta **21**.

Comando utilizzato

```
-sudo iptables -A INPUT -p tcp --dport 21 -j DROP
```

Risultato

Il servizio FTP risulta raggiungibile solo se consentito dalle regole firewall, riducendo significativamente il rischio di sfruttamento della vulnerabilità.

3. Verifica delle modifiche

Al termine degli interventi è stata eseguita una nuova scansione con Tenable Nessus utilizzando la stessa policy della scansione iniziale. L'analisi ha confermato che i servizi oggetto della remediation risultano disattivati oppure correttamente filtrati dal firewall, dimostrando l'efficacia delle modifiche apportate. La validazione finale conferma quindi la corretta riduzione della superficie di attacco del sistema, come richiesto dalla consegna dell'esercitazione.

